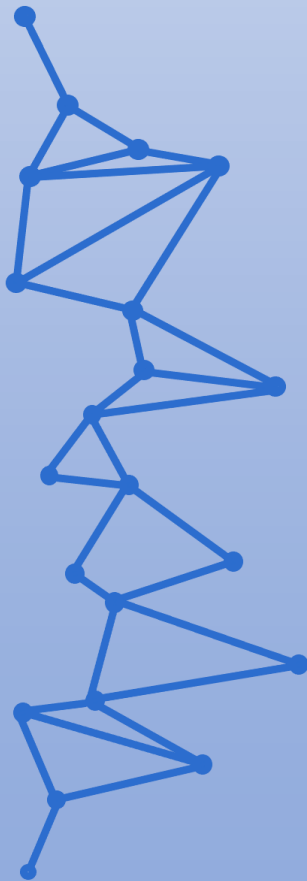




Curso de Especialización de Ciberseguridad en Entornos de Tecnología de la Información (CETI)



Incidentes de Ciberseguridad

UD02. Clasificación de riesgos y
potenciales incidentes.
Tarea Online.

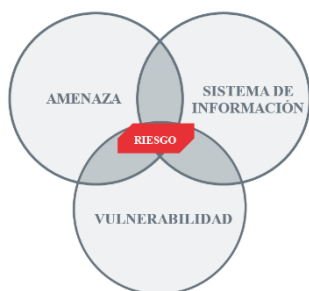
JUAN ANTONIO GARCIA MUELAS

INDICE

	Pag
1. Descripción de la tarea	2
2. Priorización y jerarquía de datos	3
3. Valoración de los dominios de seguridad	7
4. Determinación de las amenazas y sus salvaguardas	9
5. Estimación del riesgo que tendría que considerar la empresa para estudio y toma de decisiones	13
6. Taxonomía de incidentes	18
7. Webgrafía	19

1.- Descripción de la tarea.

Clasificación de riesgos y potenciales incidentes.



INCIBE. Riesgo (CCO)

Un Sistema de Gestión de Seguridad de la Información debe disponer de un correcto sistema de gestión de riesgos.

Un proceso de gestión de riesgos de seguridad de la información trata de identificar, comprender, evaluar y mitigar los riesgos.

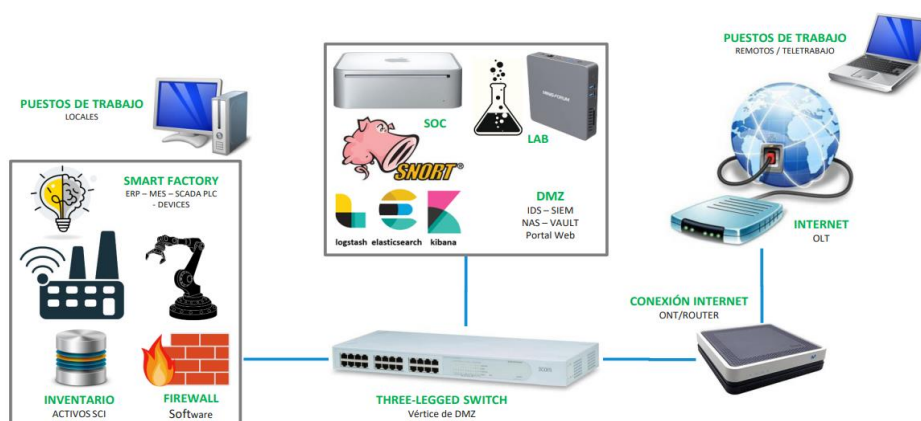
El concepto de riesgo se corresponde con la probabilidad de que se produzca un incidente de seguridad, materializándose una amenaza y causando pérdidas o daños. El riesgo depende entonces de los siguientes factores: la probabilidad de que la amenaza se materialice aprovechando una vulnerabilidad y produciendo un daño o impacto. El producto de estos factores representa el riesgo.

En esta tarea realizaremos un análisis y gestión de riesgos en la empresa ficticia de la unidad anterior para evitar o disminuir la probabilidad de que se produzcan diversos incidentes. Para este análisis seguiremos la metodología MAGERIT v.3 desarrollada por el gobierno español.

Además, haremos uso de la herramienta PILAR (versión Basic) que implementa la metodología MAGERIT que ha sido desarrollada por el Centro Criptológico Nacional (CCN). Este software es privativo y debe licenciarse, pero provee de una licencia de evaluación de 30 días, que es la que usaremos en este caso práctico.

¿Qué te pedimos que hagas?

- ✓ **Introducción: Diagrama de bloques y detalles de activos de la empresa.**
La empresa tiene el siguiente diagrama de bloques:



La empresa tiene los siguientes activos materiales principales:

Activo	Dirección IP	Sistema Operativo	Modelo Máquina	Función Empresa
Router	192.168.1.1	Askey SO	RTF3505VW	Router conexión Internet
Switch	192.168.1.11	3COM SO	SuperStack 3 3300XM	Three-Legged Switch
SOC	192.168.1.101	MacOS Ventura	Mac Mini M1	IDS/SIEM/NAS/VAULT
Labo_Server	192.168.1.102	Debian 11	MinisForum HM90	Servidor Laboratorio
ERP	192.168.1.25	Debian 11	ProLiant uServer Intel Xeon E	Servidor Gestor Empresarial
MES	192.168.1.24	Raspbian	Raspberry Pi 4B	Servidor Gestor Factoría
SCADA	192.168.1.23	Raspbian	Raspberry Pi 4B	Supervisión / Control / Firewall / Inventario
PLC	192.168.1.22	Raspbian	Raspberry Pi 4B	Controlador lógico
DEVICE	192.168.1.21	Raspbian	Raspberry Pi 4B	Dispositivo fabril
B.D. Inventario	192.168.1.25	MacOS Ventura	Mac Mini M1	Base de datos de Inventario
B.D. ECO/FIN	192.168.1.25	MacOS Ventura	Mac Mini M1	Base de datos ECO / FIN
Puestos trabajo	192.168.1.50-99	Windows 11 Pro	Lenovo ThinkCentre M720t	Puestos de trabajo
Maquetas, Prototipos	192.168.1.102	Debian 11	MinisForum HM90	Maquetas, prototipos, lanzaderas
Portal Web	192.168.1.102	Debian 11	MinisForum HM90	Portales web
Big Data, IA	192.168.1.50-99	Windows 11	Lenovo ThinkCentre M720t	Sistemas Big Data, IA

Nota: Todos los datos no proporcionados de la empresa deben ser definidos de forma autónoma y libre como si fueras parte de la dirección general de la empresa, justificando su elección. Por ejemplo: se puede decidir si los equipos actualmente disponen de una política de contraseñas seguras o si por el contrario no existen políticas al respecto. En cualquiera de los casos, debe exponerse en el documento de prácticas.

✓ Apartado 1: Priorización y jerarquía de activos.

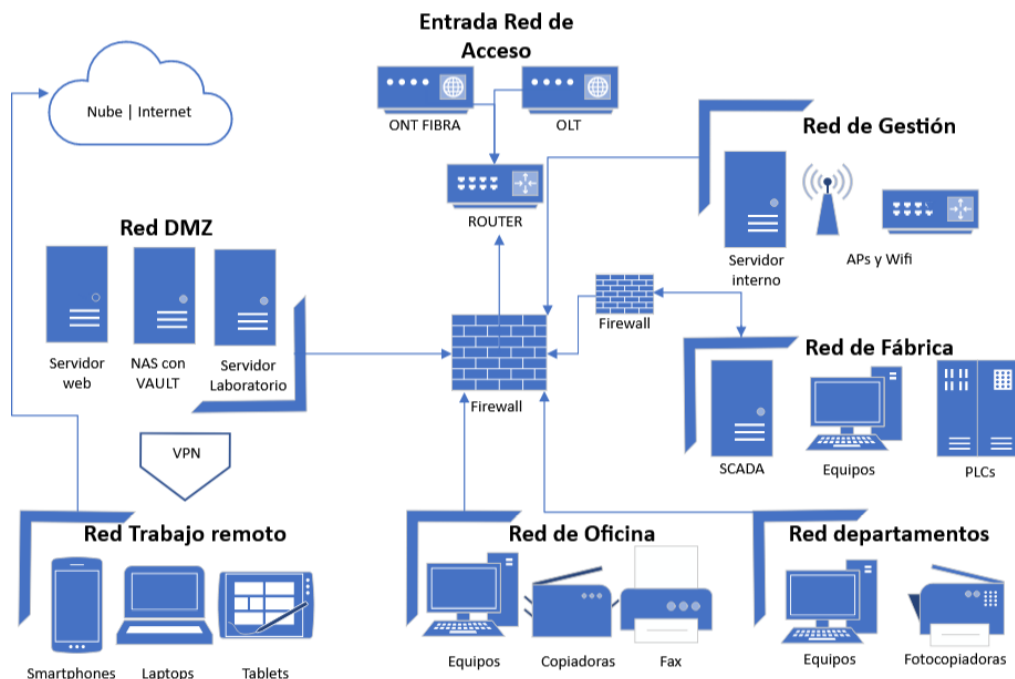
Deberás efectuar la siguiente tarea:

- A partir de la lista de activos de la introducción, se deben priorizar y jerarquizar indicando los que crees que son esenciales para la empresa. Se ordenan desde el de más importancia al de menor, además se deben indicar aquellos que dependen de otros.

De la anterior lista de activos, se debe seleccionar uno por cada uno de estos tipos indicados: activo esencial de información, activo esencial de servicio, activo de equipamiento informático y un activo de redes de comunicación. Con el uso de la herramienta PILAR se debe recoger la información de los cuatro activos anteriores.

Estos activos deben definirse en su capa correcta y en un dominio de seguridad adecuado, por lo que habrá que crear los dominios de seguridad necesarios. Muestra la ventana detallada de información de estos cuatro activos.

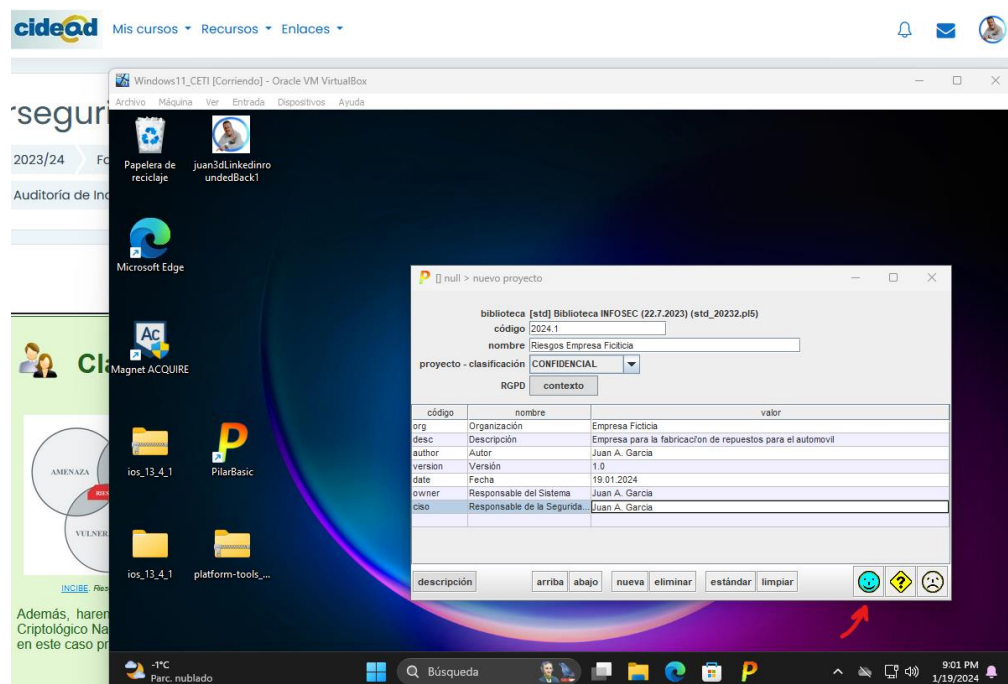
Como el enunciado propone que realizaremos un análisis y gestión de riesgos en la empresa ficticia de la unidad anterior, he creído necesario recordar el diagrama de esta, para poder integrarlo en la propuesta facilitada de esta tarea.



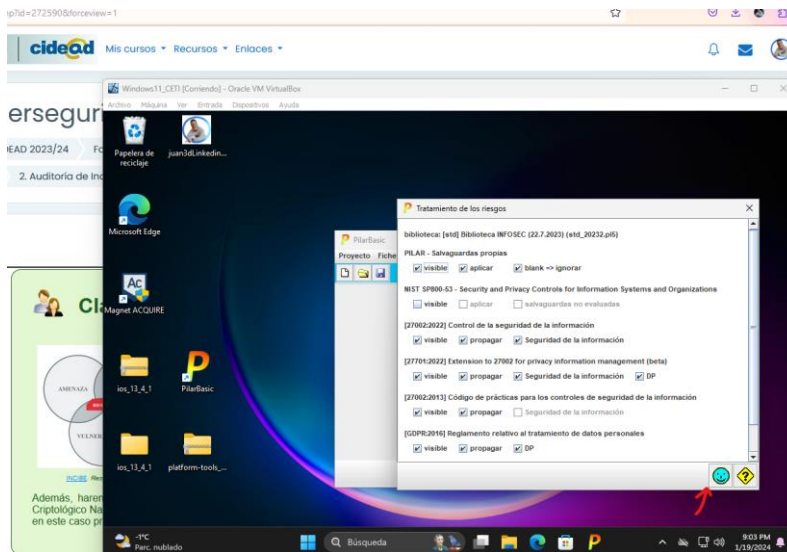
La **valoración de activos** sería la siguiente:

1. Router: Como **activo de redes de comunicación**. Conecta la empresa a Internet y el tráfico de datos. Es la puerta con el exterior y su exposición es alta.
2. Switch.
3. B.D. ECO/FIN: Las bases de datos, las clasificamos como **activo esencial de información**. Le doy prioridad a esta por contener la parte económica y financiera, pues cualquier incidente puede suponer graves daños para la continuidad.
4. B.D. Inventario.
5. SOC.
6. ERP: Como software para gestión diaria de las actividades de la empresa, es un **activo esencial de servicio**, pues cualquier falla puede comprometer el correcto funcionamiento operacional de la empresa.
7. Puestos trabajo: Los empleados realizan las tareas a través de sus equipos informáticos y de comunicaciones. Son **activos de equipamiento informático**, utilizados a diario para la consecución de objetivos.
8. MES.
9. SCADA.
10. PLC.
11. DEVICE.
12. Big Data, IA.
13. Maquetas, prototipos.
14. Labo_Server.
15. Portal web.

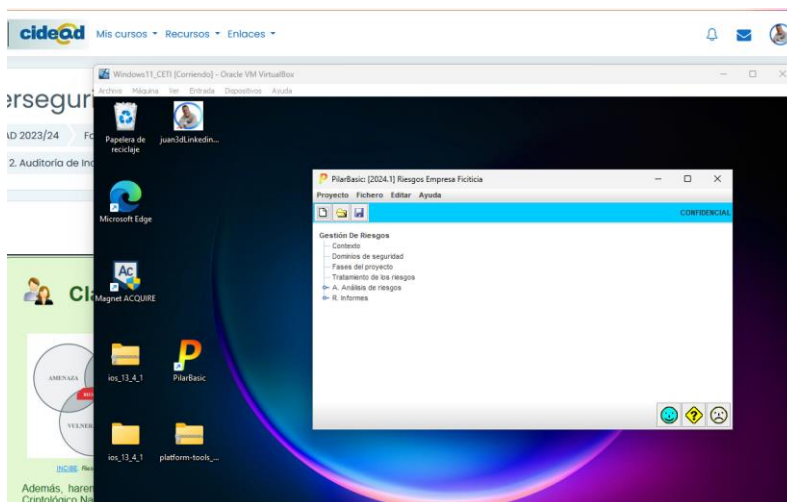
Tras la instalación e inicio con la versión de prueba de 30 días de PILAR, creo el nuevo proyecto.



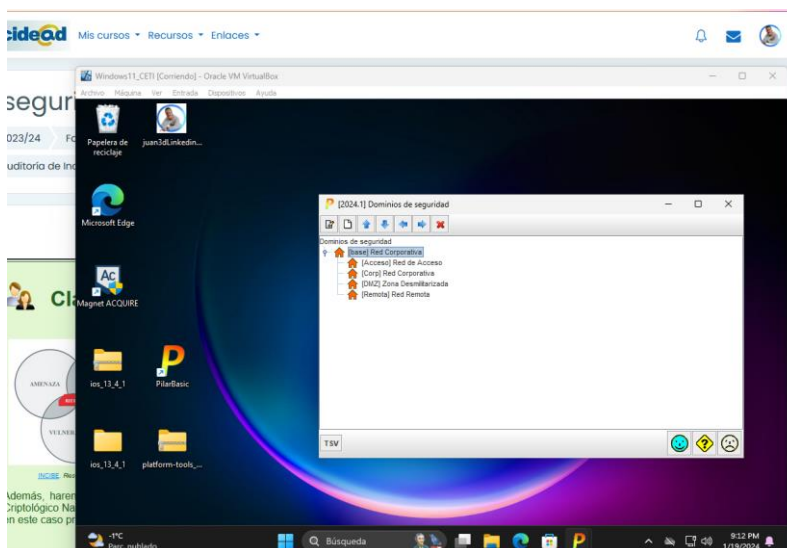
Siguiendo las instrucciones, deajo los valores por defecto en el tratamiento de los riesgos.



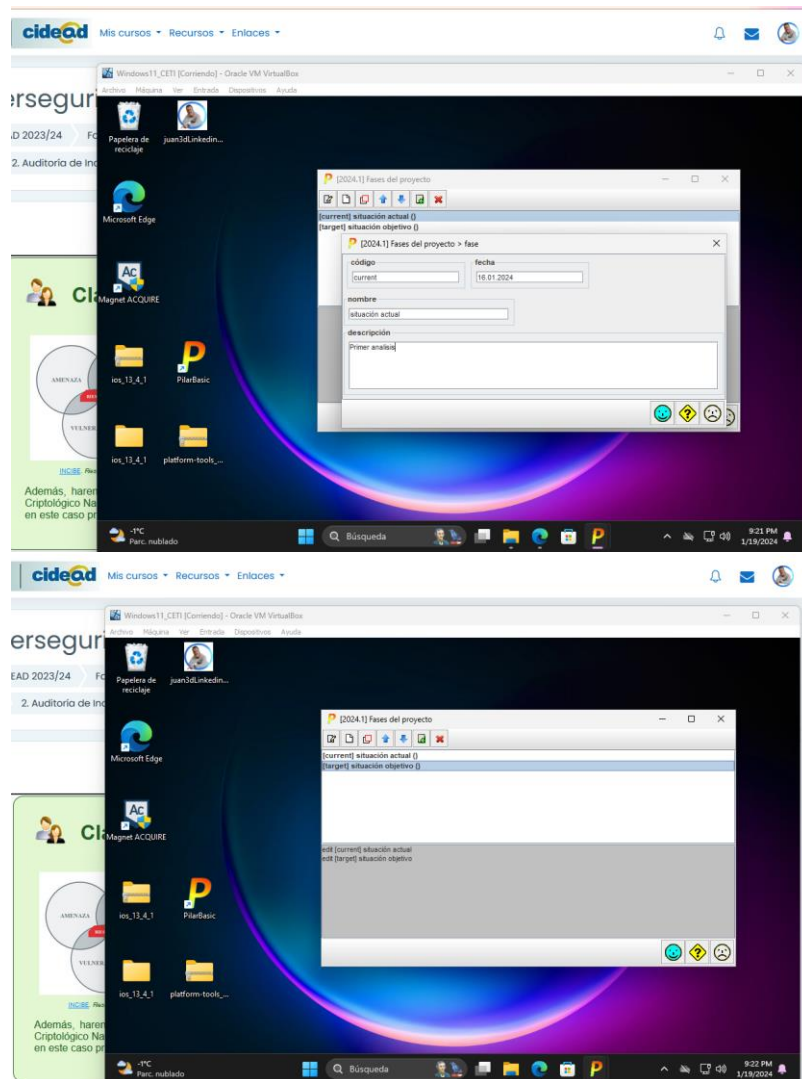
Desde el menú, accedemos a los dominios de seguridad



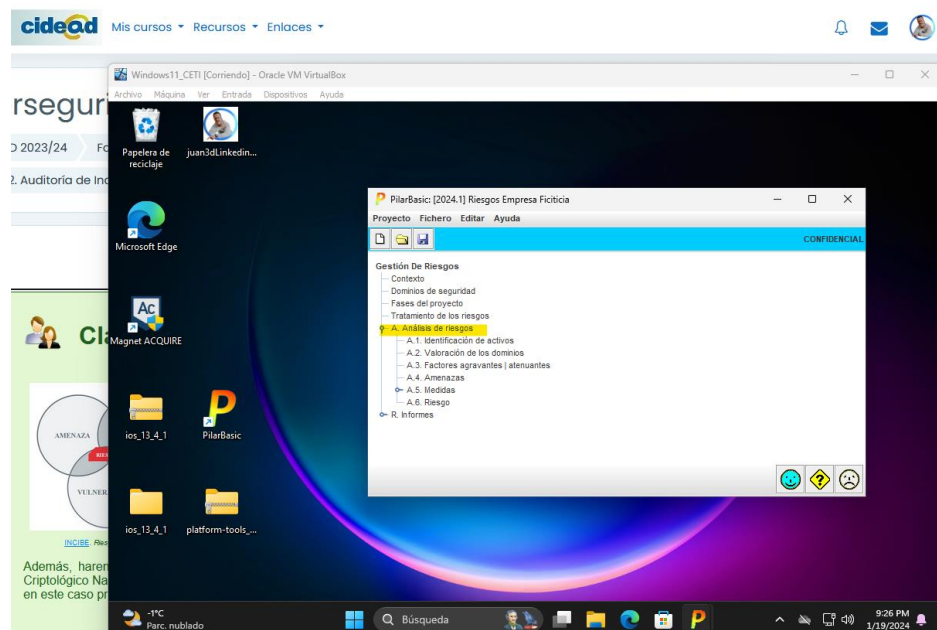
Se crean en base a lo descrito al inicio del punto.

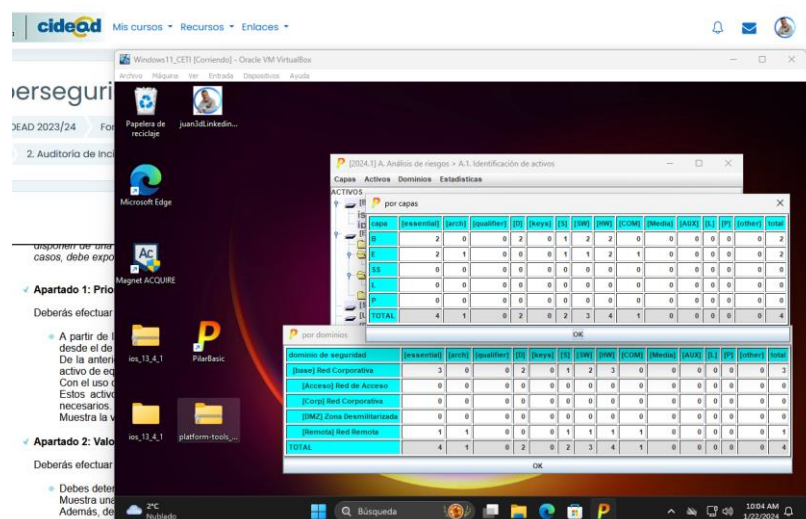
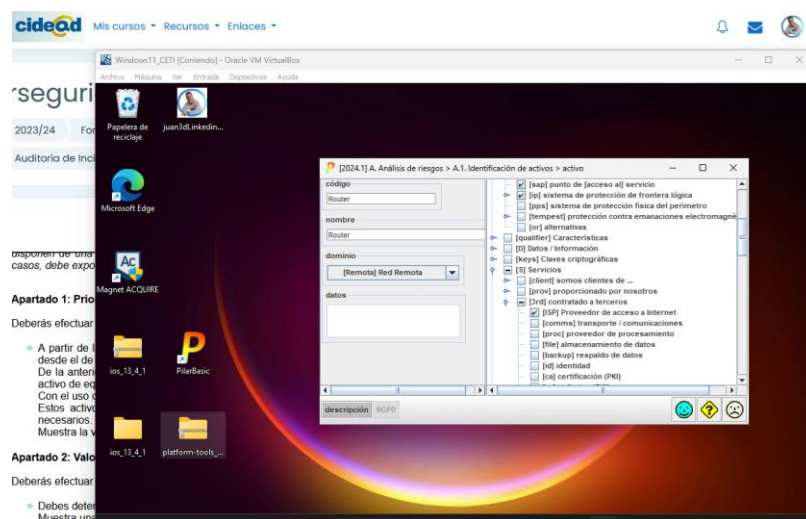
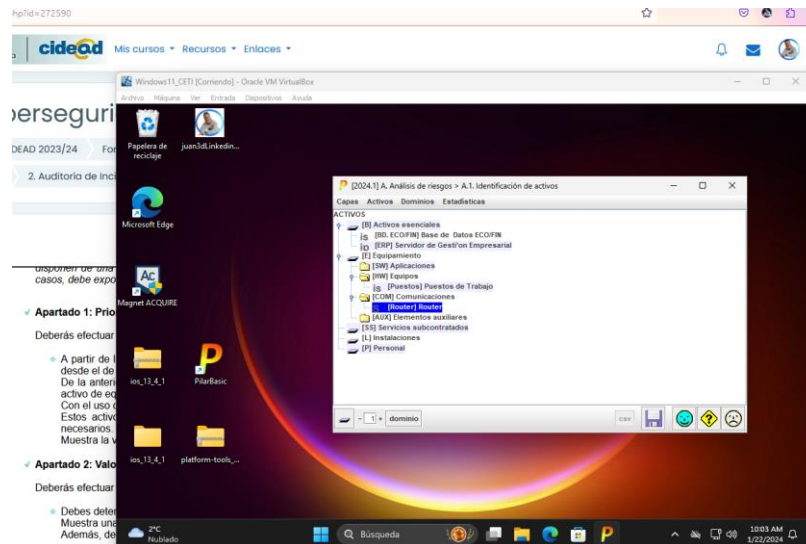


Añado las fases del proyecto.



Desde Análisis de riesgos, vamos a identificar los activos en sus capas y dominios:





✓ Apartado 2: Valoración de los dominios de seguridad.

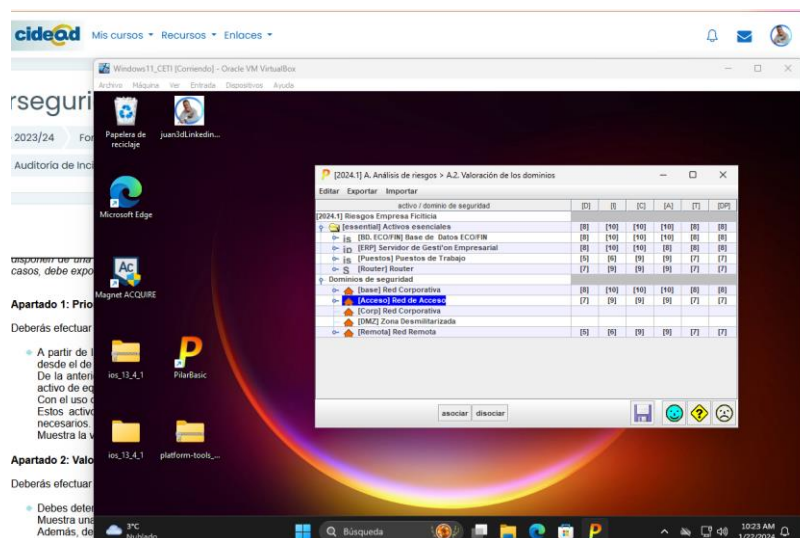
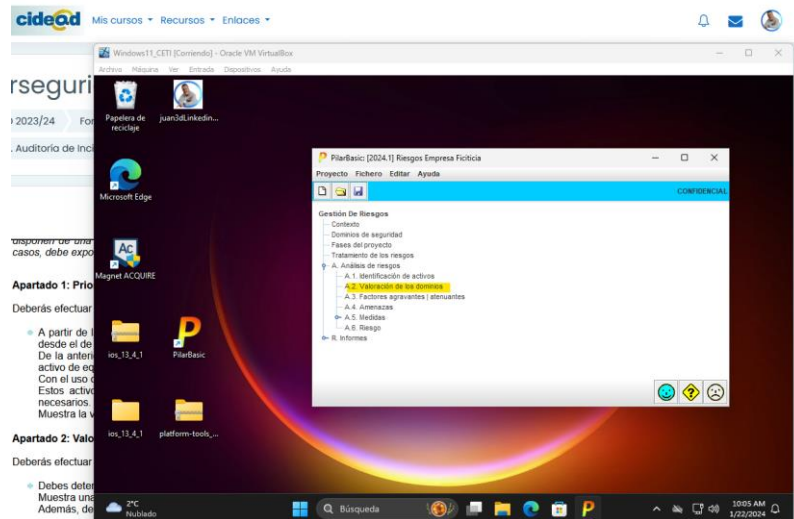
Deberás efectuar la siguiente tarea:

- Debes determinar el nivel de importancia que tienen los activos esenciales en sus diferentes dominios de seguridad definidos.

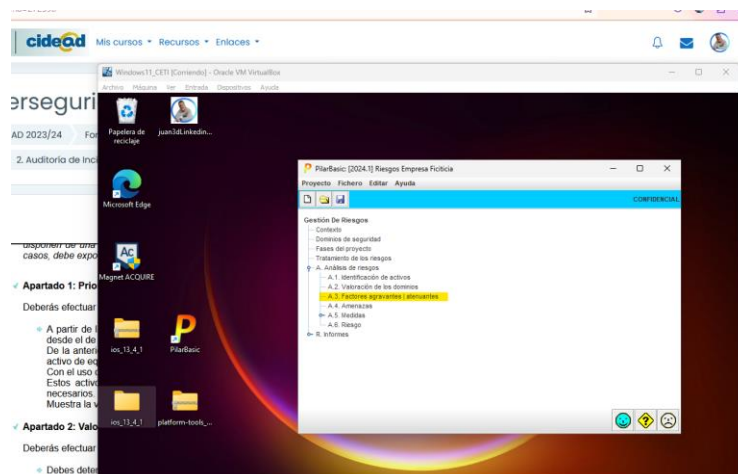
Muestra una captura de pantalla con la valoración numérica de los activos en sus dominios de seguridad.

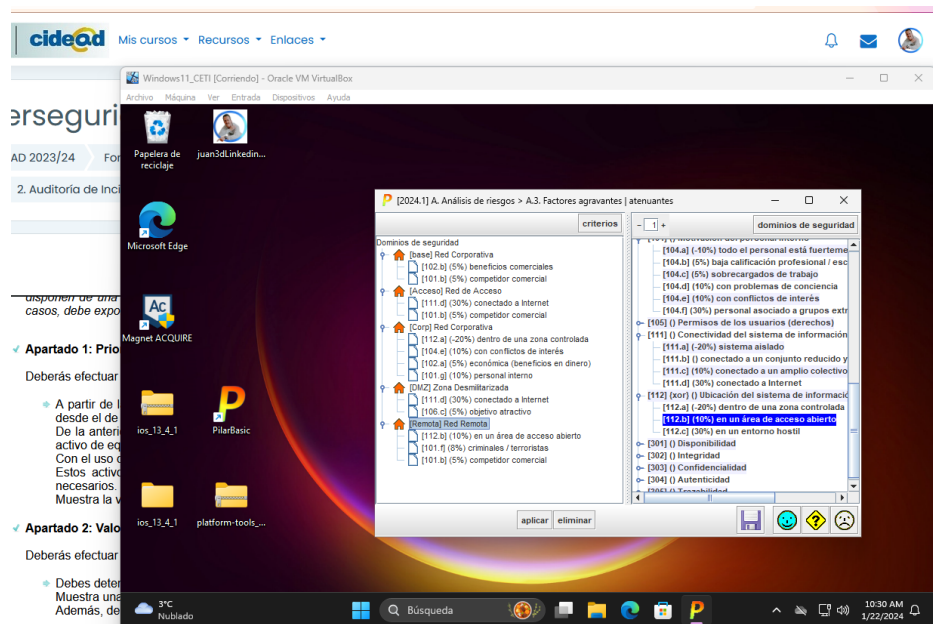
Además, debes indicar, al menos, un par de factores atenuantes y/o agravantes por cada dominio de seguridad. Muestra una captura de estos factores.

Accedemos a valorar los dominios:



Seleccionamos los factores atenuantes/agravantes para cada dominio





✓ Apartado 3: Determinación de las amenazas y sus salvaguardas dispuestas.

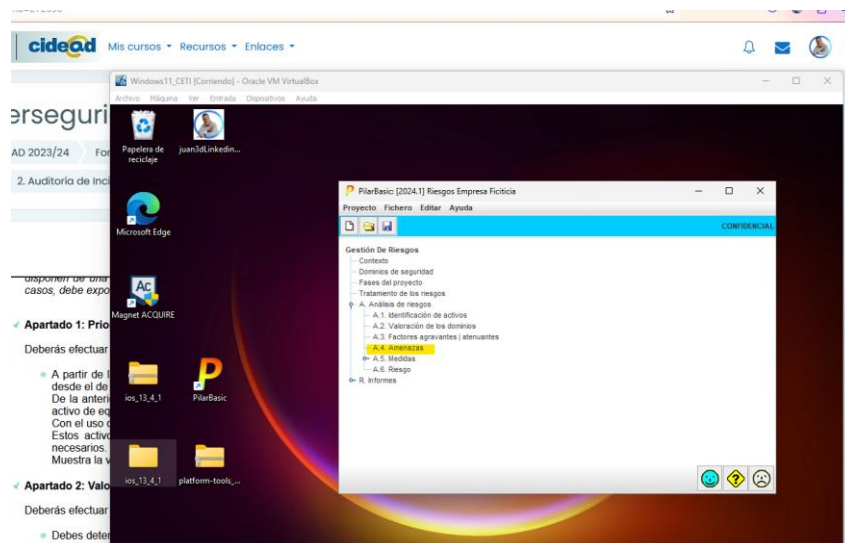
Deberás efectuar la siguiente tarea:

- Para cada uno de los cuatro activos seleccionados en el apartado uno, indica la lista de amenazas asociada a estos activos. Realiza una captura de cada activo con su lista de amenazas asociada.

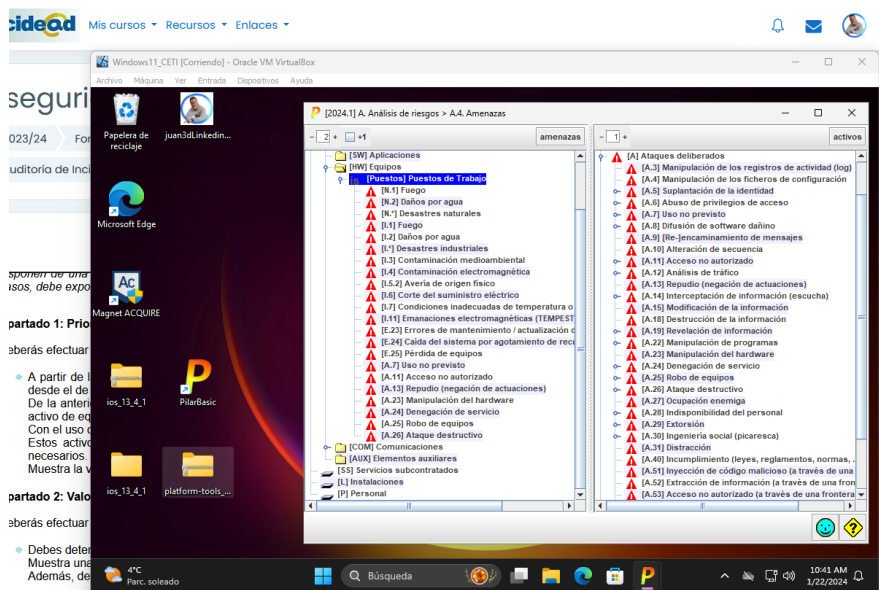
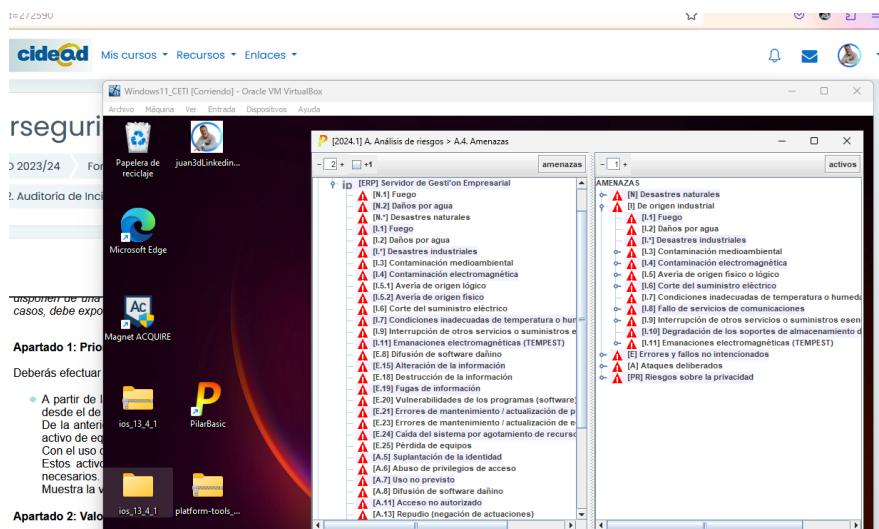
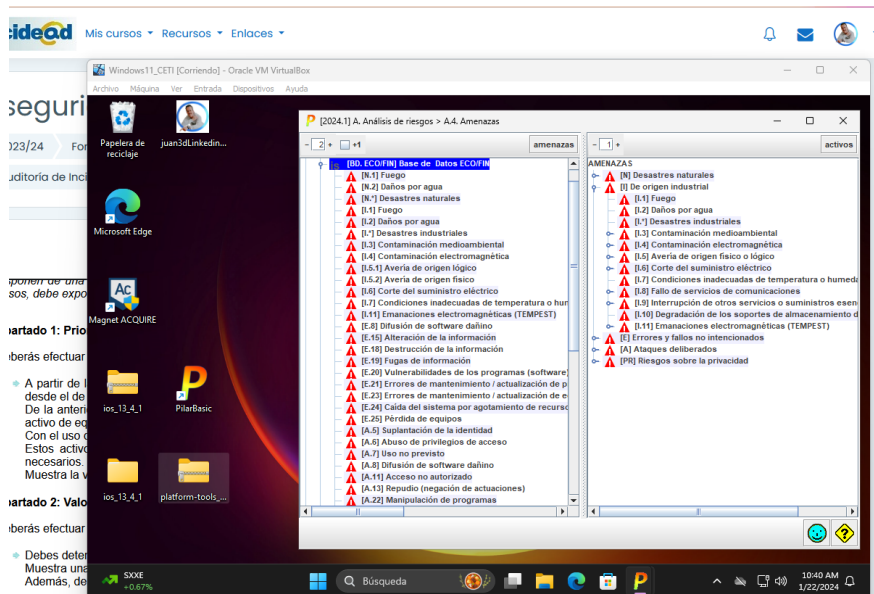
Además, para cada dominio de seguridad recoge las salvaguardas que te muestra la herramienta, ordenadas de mayor a menor prioridad según la herramienta. Para cada una de estas salvaguardas debes indicar una acción concreta que se puede realizar para llevarla a cabo en cierto grado. Incluye también el estado actual y el estado objetivo de esta salvaguarda.

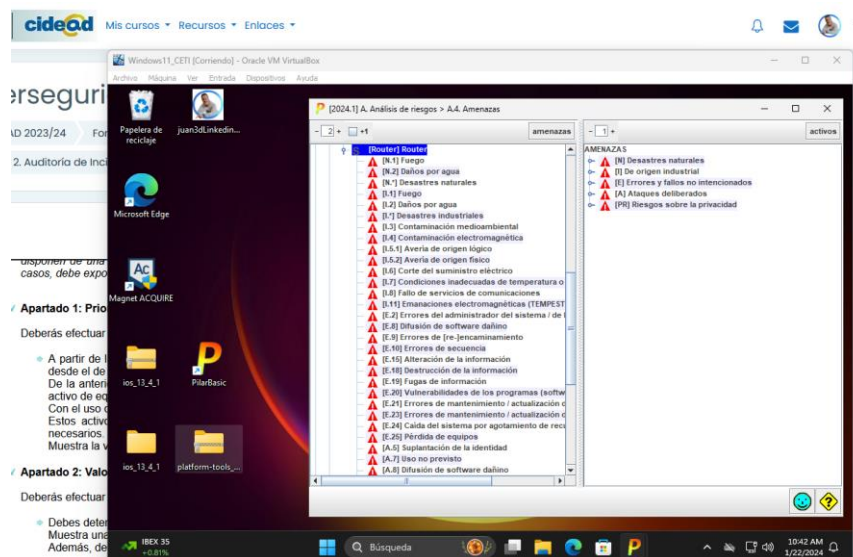
Por último, realiza una captura de pantalla en la que se ve muestren estas salvaguardas configuradas.

Accedo desde el submenú a las amenazas:

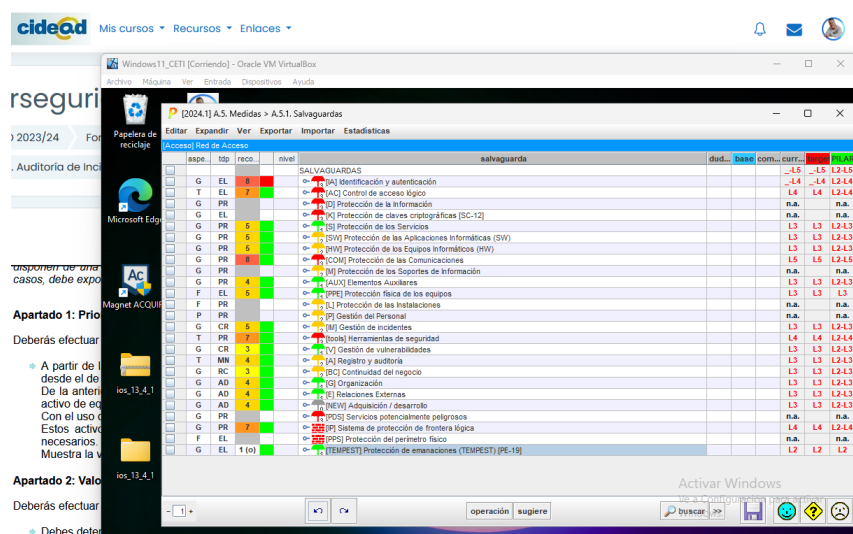
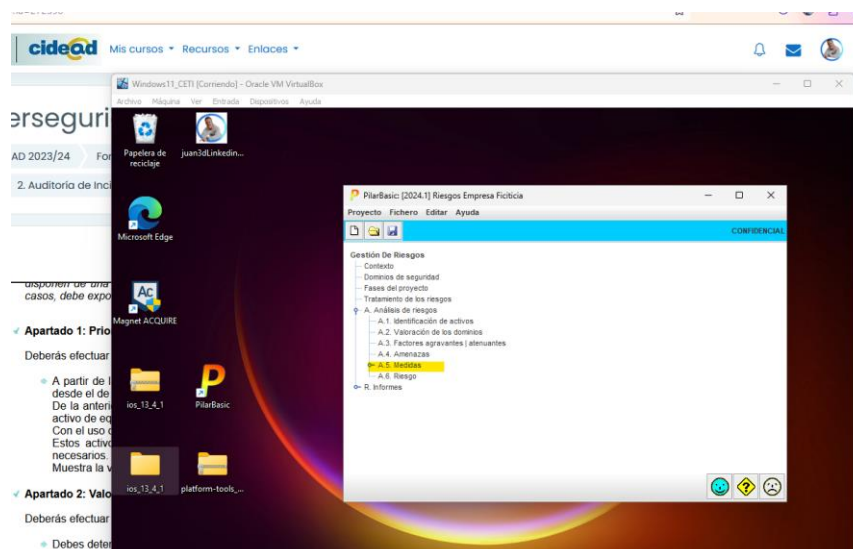


Pueden verse la listadas las amenazas por cada activo:





Accedemos a las salvaguardas desde el submenú Medidas, donde procedo a configurarlas.



Windows11_CET1 [Corriendo] - Oracle VM VirtualBox

Archivo Máquina Ver Entrada Dispositivos Ayuda

[2024.1] A.5. Medidas > A.5.1. Salvaguardas

Editar Expandir Ver Exportar Importar Estadísticas

Red Remota

aspe	tdp	reco	nivel	salvaguarda	dud...	base	com...	curr...	Info	Act
G	EL	3	5	[K] Protección de claves criptográficas (SC-12)					n.a.	n.a.
G	PR	5	5	[S] Protección de los Servicios					n.a.	n.a.
G	PR	5	5	[SW] Protección de las Aplicaciones Informáticas (SW)					n.a.	n.a.
G	PR	5	5	[HW] Protección de los Equipos Informáticos (HW)					L3	L3
G	PR	5	5	[COM] Protección de las Comunicaciones					n.a.	n.a.
G	PR	5	5	[SI] Protección de los Soportes de Información					n.a.	n.a.
G	PR	5	5	[AUX] Elementos Auxiliares					L3	L3
F	EL	5	5	[PPE] Protección física de los equipos					L3	L3
F	PR	5	5	[LI] Protección de las Instalaciones					n.a.	n.a.
P	PR	5	5	[PI] Gestión del Personal					n.a.	n.a.
T	PR	5	5	[MI] Gestión de incidentes					L3	L3
T	PR	5	5	[tools] Herramientas de seguridad					L3	L3
G	CR	5	5	[V] Gestión de vulnerabilidades					n.a.	n.a.
T	PR	5	5	[A] Registro y auditoría					L3	L3
G	RC	2 (a)	5	[BC] Continuidad del negocio					L2	L2
G	AD	5	5	[O] Organización					L3	L3
G	AD	5	5	[E] Relaciones Externas					L3	L3
G	AD	5	5	[NEW] Adquisición / desarrollo					L3	L3
G	PR	5	5	[POS] Servicios potencialmente peligrosos					L3	L3
G	PR	5	5	[PF] Sistema de protección de frontera lógica					n.a.	n.a.
F	EL	5	5	[PPS] Protección del perímetro físico					n.a.	n.a.
G	EL	1 (a)	5	[TEMPEST] Protección de emanaciones (TEMPEST) [PE-19]					L3	L3

14.1: [PPE] Protección física de los equipos
13.1: [HW] Protección de los Equipos Informáticos (HW)
8.6: [MI] Gestión de incidentes
8.0: [AUX] Elementos Auxiliares
8.0: [A] Registro y auditoría
8.4: [tools] Herramientas de seguridad
7.8: [NEW] Adquisición / desarrollo

Activar Windows

operación sugiere

Búsqueda

12:06 PM 1/22/2024

Windows11_CET1 [Corriendo] - Oracle VM VirtualBox

Archivo Máquina Ver Entrada Dispositivos Ayuda

[2024.1] A.5. Medidas > A.5.1. Salvaguardas

Editar Expandir Ver Exportar Importar Estadísticas

Red Corporativa

aspe	tdp	reco	nivel	salvaguarda	dud...	base	com...	curr...	Info	Act
G	EL	3	5	[A] Identificación y autenticación					-L5	-L5
T	EL	7	5	[AC] Control de acceso lógico					-L4	-L4
G	PR	5	5	[D] Protección de la Información					L4	L4
G	EL	5	5	[K] Protección de claves criptográficas (SC-12)					L5	L5
G	PR	5	5	[S] Protección de los Servicios					L4	L4
G	PR	5	5	[SW] Protección de las Aplicaciones Informáticas (SW)					L4	L4
G	PR	5	5	[HW] Protección de los Equipos Informáticos (HW)					L3	L3
G	PR	5	5	[COM] Protección de las Comunicaciones					L3	L3
G	PR	5	5	[SI] Protección de los Soportes de Información					n.a.	n.a.
G	PR	5	5	[AUX] Elementos Auxiliares					n.a.	n.a.
F	EL	5	5	[PPE] Protección física de los equipos					L3	L3
F	PR	5	5	[LI] Protección de las Instalaciones					L4	L4
P	PR	5	5	[PI] Gestión del Personal					n.a.	n.a.
G	CR	6	5	[MI] Gestión de incidentes					L4	L4
T	PR	7	5	[tools] Herramientas de seguridad					L4	L4
G	CR	3	5	[V] Gestión de vulnerabilidades					L3	L3
T	PR	4	5	[A] Registro y auditoría					L3	L3
G	RC	3	5	[BC] Continuidad del negocio					L3	L3
G	AD	5	5	[O] Organización					L3	L3
G	AD	5	5	[E] Relaciones Externas					L3	L3
G	AD	5	5	[NEW] Adquisición / desarrollo					L3	L3
G	PR	5	5	[POS] Servicios potencialmente peligrosos					n.a.	n.a.
G	PR	5	5	[PF] Sistema de protección de frontera lógica					n.a.	n.a.
F	EL	5	5	[PPS] Protección del perímetro físico					n.a.	n.a.
G	EL	1 (a)	5	[TEMPEST] Protección de emanaciones (TEMPEST) [PE-19]					L3	L3

Activar Windows

operación sugiere

Búsqueda

12:16 PM 1/22/2024

Windows11_CET1 [Corriendo] - Oracle VM VirtualBox

Archivo Máquina Ver Entrada Dispositivos Ayuda

[2024.1] A.5. Medidas > A.5.1. Salvaguardas

Editar Expandir Ver Exportar Importar Estadísticas

Acceso Red de Acceso

aspe	tdp	reco	nivel	salvaguarda	dud...	base	com...	curr...	Info	Act
G	EL	3	5	[A] Identificación y autenticación					-L5	-L5
T	EL	7	5	[AC] Control de acceso lógico					-L4	-L4
G	PR	5	5	[D] Protección de la Información					L4	L4
G	EL	5	5	[K] Protección de claves criptográficas (SC-12)					L5	L5
G	PR	5	5	[S] Protección de los Servicios					L3	L3
G	PR	5	5	[SW] Protección de las Aplicaciones Informáticas (SW)					L3	L3
G	PR	5	5	[HW] Protección de los Equipos Informáticos (HW)					L3	L3
G	PR	5	5	[COM] Protección de las Comunicaciones					L5	L5
G	PR	5	5	[SI] Protección de los Soportes de Información					n.a.	n.a.
G	PR	5	5	[AUX] Elementos Auxiliares					L3	L3
F	EL	5	5	[PPE] Protección física de los equipos					L3	L3
F	PR	5	5	[LI] Protección de las Instalaciones					n.a.	n.a.

por dominios

dominio de seguridad	IA	AC	D	K	S	SW	HW	COM	MI	AUX	PPE	LI	PPS	TEMPEST	total
[Base] Red Corporativa	36	126	119	236	145	215			45	11	106	103	38	98	68
[Acceso] Red de Acceso	36	126		236	145	215	164		45	11	106	103	38	98	68
[Corp] Red Corporativa															
[DMZ] Zona Desmilitarizada															
[Remota] Red Remota															
TOTAL	72	252	119	472	290	430	164	0	135	22	212	206	76	294	204

OK

Activar Windows

operación sugiere

Búsqueda

12:18 PM

- ✓ **Apartado 4: Estimación del riesgo que tendría que considerar la empresa para su estudio y toma de decisiones.**

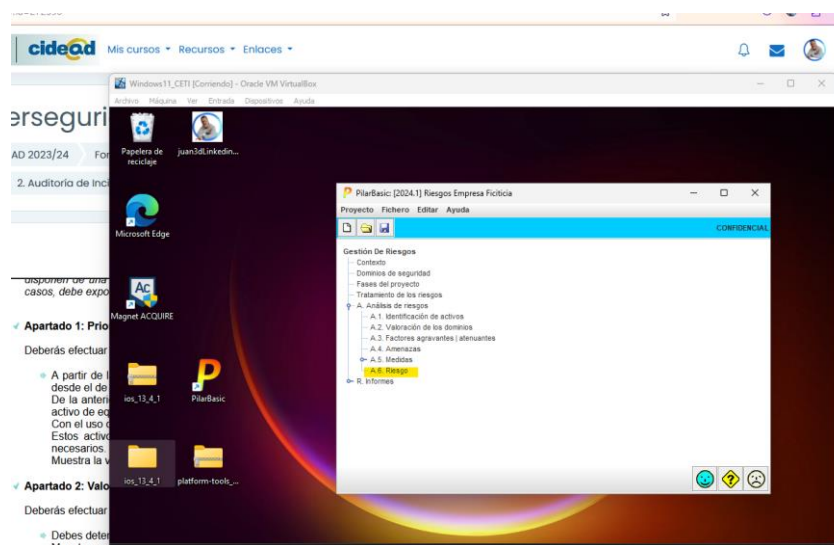
Deberás efectuar la siguiente tarea:

- Para cada uno de los cuatro activos seleccionados en el apartado uno, indica la estimación del estado del riesgo a asumir por la empresa. Se debe indicar la estimación actual (current) y la estimación objetivo (target).

Calcula la bajada que se produce en los riesgos en cada uno de los criterios de seguridad para cada activo.

Además, muestra una captura de la gráfica de riesgos de tipo "Área" en la que se muestran los cuatro activos con sus valores actuales, objetivo y recomendados por PILAR.

Revisamos la información generada desde Riesgos:



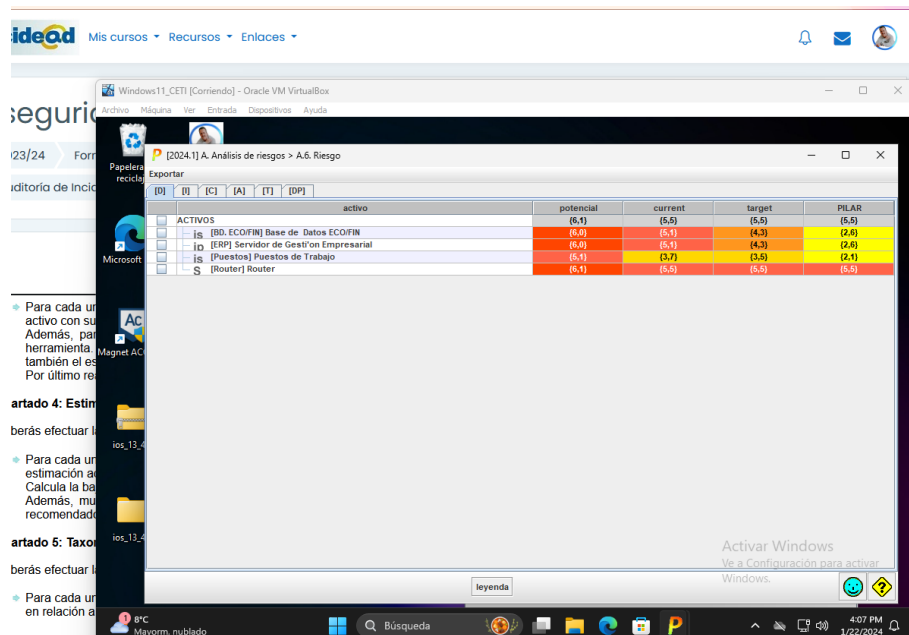
Vemos las mejoras de criticidad en los activos.

The screenshot shows the 'Análisis de riesgos' application with a table of risk analysis results. The table has columns for 'ACTIVOS', 'potencial', 'current', 'target', and 'PILAR'. The rows list various assets and their associated risks, with numerical values and color-coded indicators (yellow, orange, red) representing the risk levels.

ACTIVOS	potencial	current	target	PILAR
[B] ECOFIN Base de Datos ECOFIN	(5,5)	(5,7)	(5,4)	(5,2)
[D] disponibilidad	(2,6)	(5,2)	(5,2)	(2,3)
[I] integridad de los datos	(2,6)	(5,2)	(5,2)	(2,3)
[C] confidencialidad de los datos			(5,2)	
[A] autenticidad de los usuarios y de la información			(5,2)	
[T] trazabilidad del servicio y de los datos				(2,3)
[DP] Datos personales				(3,0)
[E] ERP Servidor de Gestión Empresarial	(2,6)	(5,2)	(5,2)	(4,6)
[D] disponibilidad	(2,6)	(5,2)	(5,2)	(2,3)
[I] integridad de los datos		(5,2)		
[C] confidencialidad de los datos			(5,2)	
[A] autenticidad de los usuarios y de la información				(4,6)
[T] trazabilidad del servicio y de los datos				(2,3)
[DP] Datos personales				(3,0)
[P] Puestos de Trabajo	(2,1)	(0,73)	(4,4)	
[D] disponibilidad	(2,1)			(1,9)
[I] integridad de los datos		(0,73)		
[C] confidencialidad de los datos			(4,4)	
[A] autenticidad de los usuarios y de la información				(1,9)
[T] trazabilidad del servicio y de los datos				
[DP] Datos personales				(2,3)
[R] Router	(5,5)	(5,7)	(5,4)	(3,7)
[D] disponibilidad	(5,5)			
[I] integridad de los datos		(5,7)		
[C] confidencialidad de los datos			(5,4)	
[A] autenticidad de los usuarios y de la información				(3,7)
[T] trazabilidad del servicio y de los datos				(2,3)
[DP] Datos personales				

Vamos a calcular la bajada según los distintos criterios.

Respecto a disponibilidad:



The screenshot shows a risk analysis tool interface. A table titled 'Exportar' displays the following data:

activo	potencial	current	target	PILAR
ACTIVOS	(5,1)	(5,5)	(5,5)	(5,5)
is [BD, ECO/FIN] Base de Datos ECO/FIN	(5,0)	(5,1)	(4,3)	(2,6)
id [ERP] Servidor de Gestión Empresarial	(5,0)	(5,1)	(4,3)	(2,6)
is [Puestos] Puestos de Trabajo	(5,1)	(3,7)	(3,5)	(2,1)
S [Router] Router	(5,1)	(5,5)	(5,5)	(5,5)

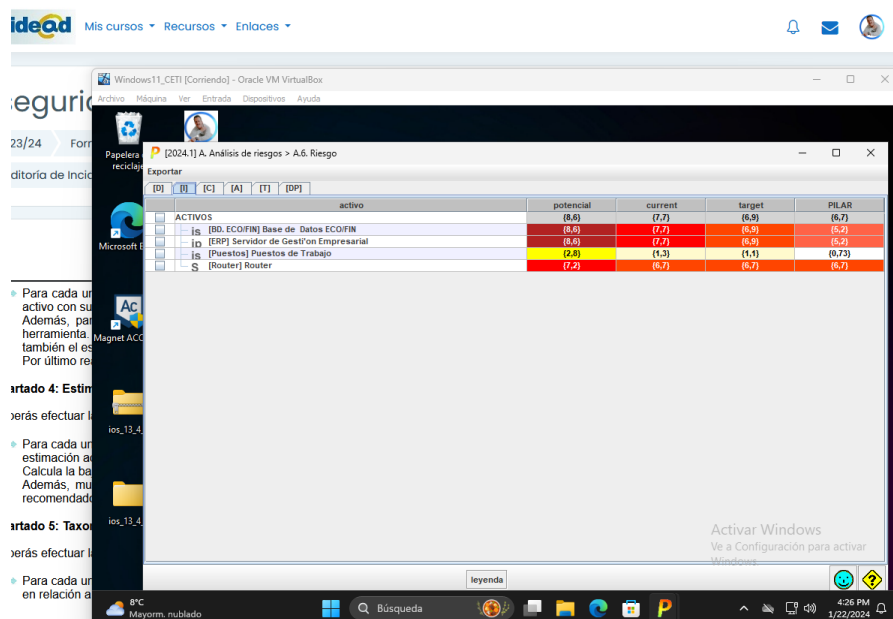
B.D. Datos ECO/FIN: Bajada de 0.8 puntos

ERP: Bajada de 0.8 puntos

Puestos de trabajo: Bajada de 0.2 puntos

Router: Bajada de 0 puntos

Vemos la Integridad:



The screenshot shows a risk analysis tool interface. A table titled 'Exportar' displays the following data:

activo	potencial	current	target	PILAR
ACTIVOS	(8,6)	(7,7)	(6,9)	(5,7)
is [BD, ECO/FIN] Base de Datos ECO/FIN	(8,6)	(7,7)	(6,9)	(5,7)
id [ERP] Servidor de Gestión Empresarial	(8,6)	(7,7)	(6,9)	(5,7)
is [Puestos] Puestos de Trabajo	(2,1)	(1,5)	(1,1)	(0,75)
S [Router] Router	(7,6)	(6,7)	(6,7)	(6,7)

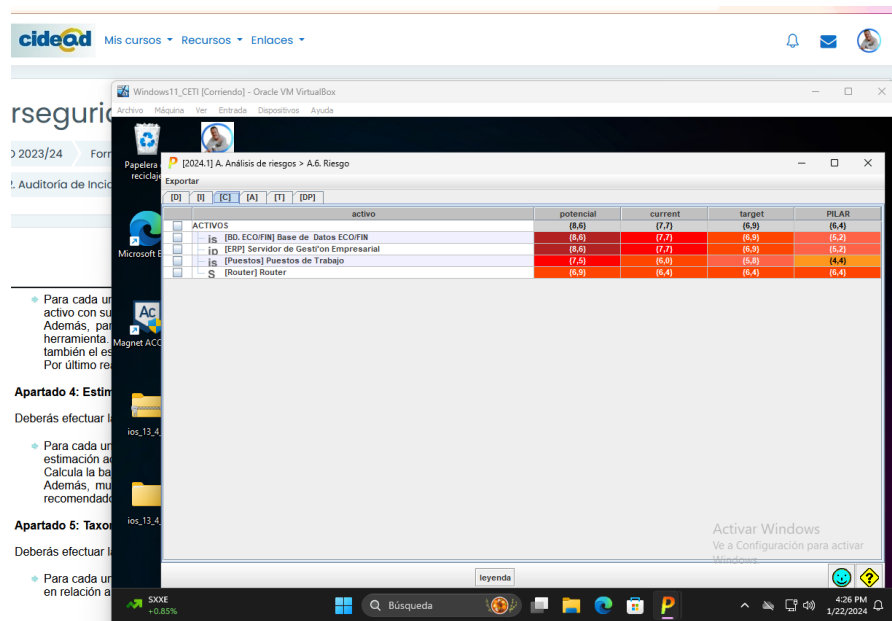
B.D. Datos ECO/FIN: Bajada de 0.8 puntos

ERP: Bajada de 0.8 puntos

Puestos de trabajo: Bajada de 0.2 puntos

Router: Bajada de 0 puntos

Vemos la Confidencialidad:



The screenshot shows a risk analysis tool interface. A table titled 'Exportar' displays the following data:

	activo	potencial	current	target	PILAR
ACTIVOS		(8,6)	(7,7)	(6,9)	(6,4)
is	[BD, ECOFIN] Base de Datos ECOFIN	(8,6)	(7,7)	(6,9)	(6,2)
id	[ERP] Servidor de Gest'ion Empresarial	(8,6)	(7,7)	(6,9)	(6,2)
is	[Puestos] Puestos de Trabajo	(7,8)	(6,9)	(5,8)	(4,4)
S	[Router] Router	(6,9)	(6,4)	(6,4)	(6,4)

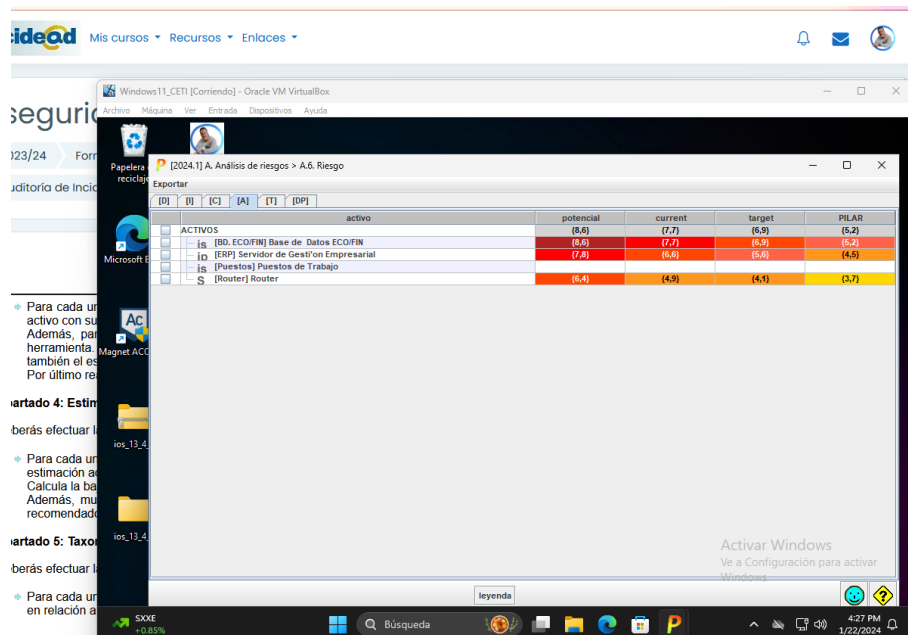
B.D. Datos ECO/FIN: Bajada de 0.8 puntos

ERP: Bajada de 0.8 puntos

Puestos de trabajo: Bajada de 0.2 puntos

Router: Bajada de 0 puntos

Vemos la Autenticidad:



The screenshot shows the same risk analysis tool interface, but with the 'Autenticidad' (Authenticity) scores. The table data is as follows:

	activo	potencial	current	target	PILAR
ACTIVOS		(8,6)	(7,7)	(6,9)	(6,2)
is	[BD, ECOFIN] Base de Datos ECOFIN	(8,6)	(7,7)	(6,9)	(6,2)
id	[ERP] Servidor de Gest'ion Empresarial	(7,8)	(6,8)	(6,6)	(4,6)
is	[Puestos] Puestos de Trabajo	(8,4)	(4,8)	(4,1)	(3,7)
S	[Router] Router				

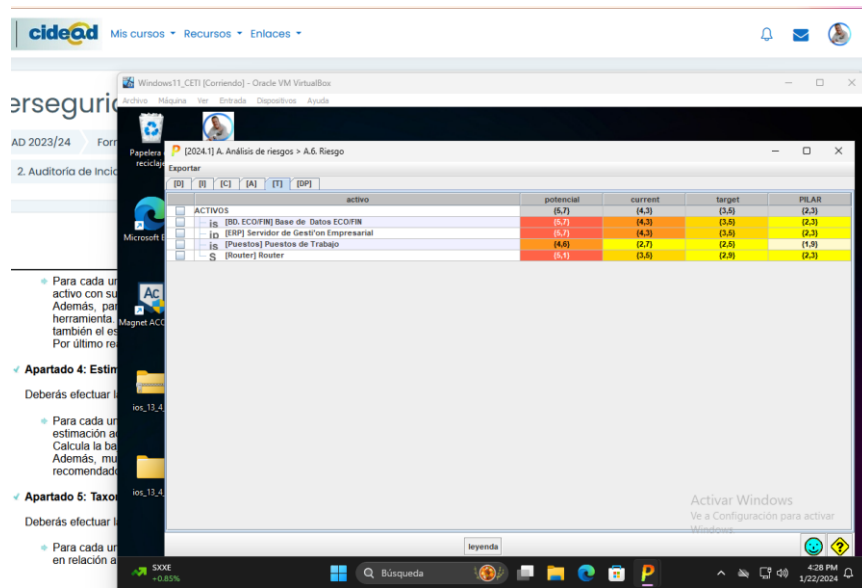
B.D. Datos ECO/FIN: Bajada de 0.8 puntos

ERP: Bajada de 1 punto

Puestos de trabajo:

Router: Bajada de 0.8 puntos

Vemos la Trazabilidad:



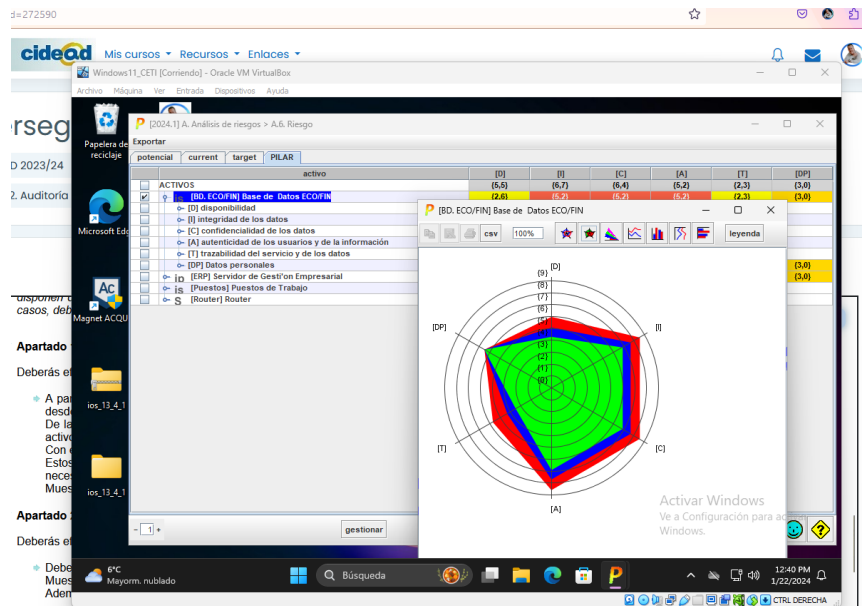
B.D. Datos ECO/FIN: Bajada de 0.8 puntos

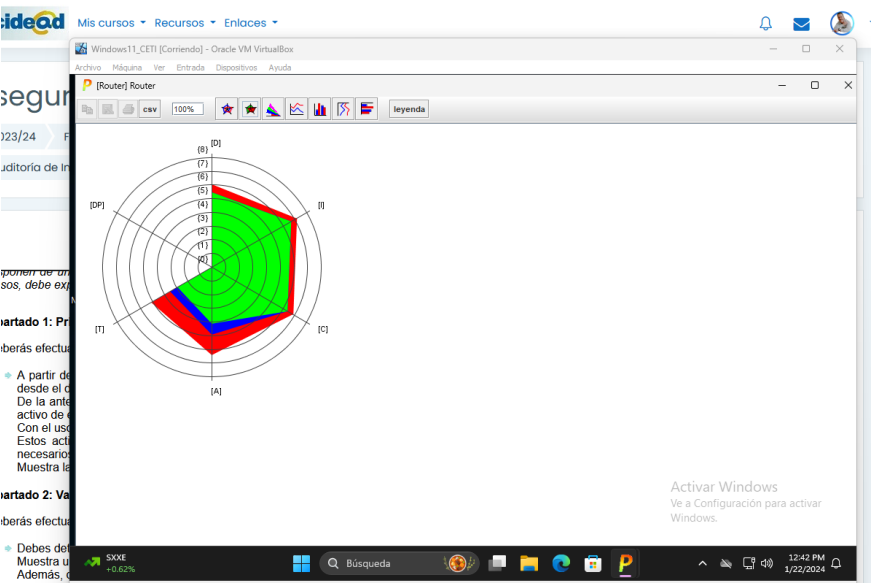
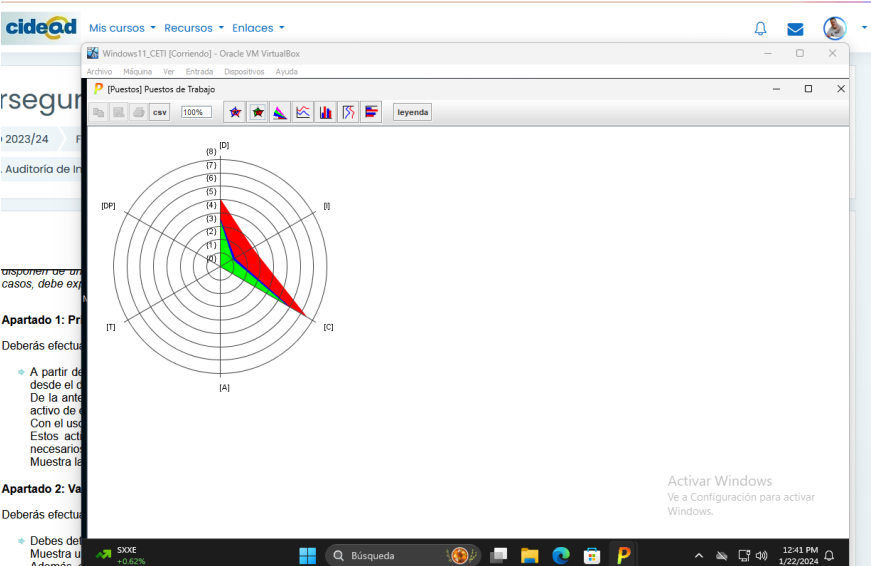
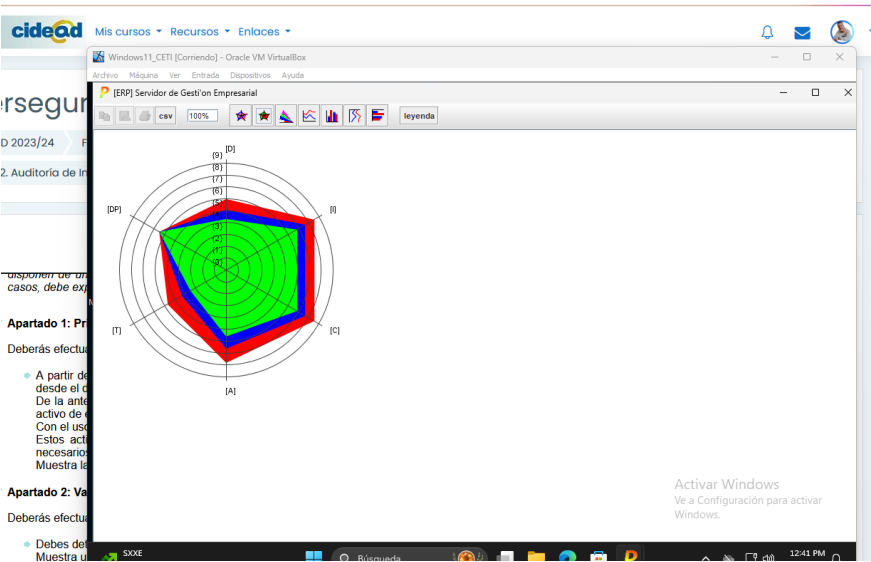
ERP: Bajada de 0.8 puntos

Puestos de trabajo: Bajada de 0.2 puntos

Router: Bajada de 0.6 puntos

Mostramos los distintos gráficos de tipo "Área":





✓ **Apartado 5: Taxonomía de incidentes.**

Deberás efectuar la siguiente tarea:

- Para cada uno de los cuatro activos seleccionados en el apartado uno y tras el estudio de sus riesgos, determina un tipo de incidente que podría producirse en relación a sus riesgos. Para este tipo de incidente indica el grupo al que pertenece y realiza una pequeña explicación sobre este.

Activo	Riesgo	Tipo de incidente	Grupo	Explicación
Router	A.24 Denegación de servicio	Ataque DoS	Disponibilidad	Un envío masivo de peticiones hacia un servidor puede provocar la ralentización o la caída de este.
B.D. ECO/FIN	I.5.1 Avería de origen lógico	Interrupciones	Disponibilidad	Un error de mantenimiento y actualización provoca el fallo y la no disponibilidad de los datos.
ERP	E.20 Vulnerabilidades de los programas	Sistema vulnerable	Vulnerabilidad	Similar al caso anterior. Sino mantenemos actualizado de forma correcta nuestro software, puede verse expuesto a alguna vulnerabilidad.
Puestos de trabajo	A.25 Robo de equipos	Robo	Confidencialidad	La sustracción de un equipo puede comprometer la seguridad de los datos que contenga sino está debidamente protegido.

Webgrafía.

https://www.ar-tools.com/es/tools/pilar_basic/v20212/index.html

https://administracionelectronica.gob.es/pae_Home/pae_Documentacion/pae_Metodolog/pae_Magerit.html

<https://www.youtube.com/watch?v=mrNpiri6z8A>